

Meridian & Associates LLP

Global Professional Services

Information Security Overview

Version 6.1

Effective Date: January 2026

Classification: Confidential

Prepared by the Office of Strategic Communications

Meridian & Associates LLP

CONFIDENTIAL

This document contains proprietary information. Do not distribute outside of authorized RFP response teams without written consent.

Table of Contents

1	Security Governance and Organization
2	Certifications and Compliance
3	Data Encryption Standards
4	Network and Infrastructure Security
5	Endpoint Protection
6	Security Operations Center (SOC)
7	Vulnerability Management
8	Zero Trust Architecture
9	Third-Party Security Management
10	Security Awareness and Training
11	Data Loss Prevention (DLP)
12	Incident Response Lifecycle
13	AI/ML Security Controls
14	Physical Security

1. Security Governance and Organization

Information security at Meridian & Associates LLP is governed by the Global Chief Information Security Officer (CISO), who reports directly to the Chief Operating Officer and has a standing quarterly briefing with the Board of Partners. The CISO leads a team of 340 security professionals organized across six functions: Security Architecture, Security Operations, Identity and Access Management, Governance Risk and Compliance, Application Security, and Incident Response.

The Information Security Steering Committee, comprising the CISO, CIO, CTO, General Counsel, and Chief Risk Officer, meets monthly to review the security posture, approve policy changes, and allocate resources. The firm's annual information security budget exceeds \$120 million.

2. Certifications and Compliance

Meridian maintains a comprehensive set of security certifications and undergoes rigorous independent audits annually:

- SOC 2 Type II -- Certified across all service delivery environments. Annual audit performed by an independent Big 4 firm; most recent report issued October 2025 with zero exceptions.
- ISO 27001:2022 -- Certified for all global operations. Certification body: BSI Group. Last recertification: March 2025.
- ISO 27017 -- Cloud security controls certification for our managed services environments.
- ISO 27018 -- Protection of personally identifiable information in public clouds.
- ISO 22301 -- Business continuity management system certification.
- PCI DSS v4.0 -- Level 1 Service Provider for engagements handling cardholder data.
- FedRAMP Moderate -- Authorized for U.S. federal government engagements.
- HITRUST CSF v11 -- Certified for healthcare client engagements.

3. Data Encryption Standards

3.1 Data at Rest

- AES-256 encryption for all data at rest across all storage systems.
- Full-disk encryption (BitLocker/FileVault) mandatory on all endpoints.
- Database-level Transparent Data Encryption (TDE) for all production databases.
- Hardware Security Modules (HSMs) for cryptographic key management, FIPS 140-2 Level 3 certified.

3.2 Data in Transit

- TLS 1.3 enforced for all external communications; TLS 1.2 minimum for legacy integrations (with documented exception and remediation timeline).
- Mutual TLS (mTLS) for all inter-service communications within the internal network.
- IPsec VPN with AES-256-GCM for site-to-site connectivity.
- Certificate management via automated PKI with 90-day rotation for all server certificates.

4. Network and Infrastructure Security

- Micro-segmented network architecture with software-defined perimeters.
- Next-generation firewalls (Palo Alto Networks) at all network boundaries.
- Distributed Denial of Service (DDoS) mitigation via Cloudflare Enterprise.
- DNS security with DNSSEC validation and DNS-over-HTTPS for all endpoints.
- Web Application Firewall (WAF) protecting all internet-facing applications.
- Network Detection and Response (NDR) deployed across all segments.

5. Endpoint Protection

- CrowdStrike Falcon deployed on 100% of managed endpoints (72,000+ devices).
- Endpoint Detection and Response (EDR) with 24/7 managed threat hunting.
- Mobile Device Management (MDM) via Microsoft Intune for all firm-issued and BYOD devices.
- Application allowlisting on all critical infrastructure servers.
- USB and removable media controls -- disabled by default, exception-based approval process.
- Automated patch deployment within 72 hours for critical vulnerabilities, 14 days for high.

6. Security Operations Center (SOC)

Meridian operates a 24/7/365 Security Operations Center with primary facilities in Chicago and London, and a tertiary facility in Bangalore for follow-the-sun coverage. The SOC processes an average of 4.2 billion security events per day.

- SIEM Platform: Splunk Enterprise Security with custom correlation rules and ML-based anomaly detection.
- SOAR Platform: Palo Alto XSOAR for automated incident triage and response playbooks.
- Mean Time to Detect (MTTD): < 15 minutes for critical threats.
- Mean Time to Respond (MTTR): < 1 hour for critical incidents.
- Threat Intelligence: Integration with 12 commercial and open-source threat intelligence feeds, plus a dedicated in-house threat intelligence team of 18 analysts.
- Purple Team Exercises: Conducted quarterly with external red team partners.

7. Vulnerability Management

- Continuous vulnerability scanning across all environments using Qualys and Tenable.
- Critical vulnerabilities: Remediation within 24 hours.
- High vulnerabilities: Remediation within 7 days.
- Medium vulnerabilities: Remediation within 30 days.
- Annual penetration testing by two independent firms (rotating annually).
- Bug bounty program via HackerOne for internet-facing applications.
- Static Application Security Testing (SAST) and Dynamic Application Security Testing (DAST) integrated into all CI/CD pipelines.

8. Zero Trust Architecture

Meridian has implemented a comprehensive Zero Trust security model based on NIST SP 800-207 principles:

- Identity-Centric Access -- All access decisions based on verified identity, device health, and contextual risk signals. No implicit trust based on network location.
- Continuous Verification -- Session-based re-authentication every 8 hours; step-up MFA for sensitive operations.
- Least Privilege -- Role-based access control (RBAC) with quarterly access reviews and automated deprovisioning for role changes.
- Micro-Segmentation -- East-west traffic controlled by identity-aware policies; lateral movement restricted by default.
- Multi-Factor Authentication -- Enforced for all users via hardware security keys (FIDO2) or Microsoft Authenticator. SMS-based MFA prohibited.

9. Third-Party Security Management

All third-party vendors and subcontractors undergo a tiered security assessment based on data access and criticality:

- Tier 1 (Critical -- access to client data): Full security assessment, SOC 2 Type II or equivalent required, annual on-site audit, continuous monitoring.
- Tier 2 (Important -- access to internal systems): Security questionnaire (SIG Lite), evidence of penetration testing, annual reassessment.
- Tier 3 (Standard -- no data access): Self-attestation, periodic spot checks.
- Contractual Requirements: All vendors must agree to Meridian's Data Protection Addendum, which includes breach notification within 24 hours, right to audit, and data destruction upon termination.

10. Security Awareness and Training

- Mandatory annual security awareness training for all 68,000+ professionals (98.7% completion rate in FY2025).
- Monthly phishing simulations with targeted remediation training for repeat clickers.
- Role-based training for developers (OWASP Top 10, secure coding), administrators (hardening guidelines), and executives (business email compromise awareness).
- Security Champion program: 450+ trained security champions embedded in project teams.

11. Data Loss Prevention (DLP)

Meridian operates a comprehensive Data Loss Prevention program to detect and prevent unauthorized exfiltration of sensitive data across all channels:

- Endpoint DLP: Microsoft Purview DLP agents deployed on 100% of managed endpoints. Policies enforce blocking or encryption for files containing PII, client confidential data, and financial data leaving the corporate environment.
- Email DLP: All outbound email scanned in real-time for sensitive data patterns (SSN, credit card numbers, client code names, MNPI indicators). Policy violations trigger automatic encryption, quarantine, or block depending on severity.
- Cloud DLP: Cloud Access Security Broker (CASB) integration with Microsoft 365, Salesforce, and all sanctioned

SaaS applications. Policies prevent upload of classified data to unsanctioned cloud services.

- Network DLP: Deep content inspection at all network egress points. SSL/TLS inspection for encrypted traffic (with documented exceptions for banking and healthcare endpoints).
- Data classification: Four-tier classification scheme (Public, Internal, Confidential, Restricted). Automated classification applied at creation using Microsoft Purview Information Protection. Manual override requires justification and manager approval.
- DLP incident metrics FY2025: 14,200 policy violations detected; 98% automatically remediated; 42 escalated to the Insider Threat team for investigation; zero confirmed data exfiltration events.

12. Incident Response Lifecycle

Meridian's Incident Response (IR) program follows the NIST SP 800-61 framework, structured across five phases:

12.1 Detection and Analysis

- 24/7 SOC monitoring with automated alert triage via SOAR playbooks.
- Threat intelligence correlation across 12 commercial and open-source feeds.
- ML-based anomaly detection for user behavior (UEBA) and network traffic.
- Mean Time to Detect (MTTD) for critical threats: < 15 minutes.
- Severity classification (P1-P4) within 30 minutes of detection.

12.2 Containment

- Automated containment actions for P1 incidents: endpoint isolation, account suspension, network segment quarantine.
- Containment decision authority: SOC Shift Lead for P3/P4; IR Manager for P2; CISO for P1.
- Evidence preservation procedures activated in parallel (forensic imaging, log snapshots).

12.3 Eradication

- Root cause analysis initiated within 4 hours of containment.
- Malware removal, compromised credential rotation, vulnerable system patching.
- Threat hunting across the full environment to identify lateral movement or persistence.

12.4 Recovery

- System restoration from verified clean backups (immutable backups for ransomware scenarios).
- Phased recovery with enhanced monitoring: Tier 1 systems restored first within RTO targets.
- Client notification per contractual SLAs (typically within 24 hours for data-impacting incidents).
- Mean Time to Recover (MTTR) for P1 incidents: < 4 hours.

12.5 Lessons Learned

- Post-incident review (PIR) completed within 10 business days of incident closure.
- PIR report distributed to CISO, CIO, affected business unit leaders, and relevant clients.
- Remediation actions tracked to completion with executive-level accountability.
- Annual Incident Response Report published internally with trend analysis and improvement plan.
- FY2025 summary: 847 security incidents investigated; 12 classified as P1/P2; zero resulted in confirmed client data

breach; average MTTR for P1: 2 hours 48 minutes.

13. AI/ML Security Controls

As AI/ML technologies become integral to client engagements and internal operations, Meridian has implemented security controls specifically designed for AI/ML risks:

- Prompt injection defense: All client-facing and internal LLM deployments include input sanitization, output filtering, and system prompt protection. Validated through quarterly red-team exercises by the Application Security team.
- Model supply chain security: All AI/ML models (proprietary and third-party) are tracked in a Model Registry with provenance documentation, integrity checksums (SHA-256), and version control. Third-party model artifacts scanned for known vulnerabilities before deployment.
- LLM guardrails: MeridianAI (the firm's enterprise AI orchestration layer) enforces configurable guardrails including: content filtering for harmful/inappropriate outputs, PII detection and redaction in prompts and responses, hallucination detection scores, and usage rate limiting.
- Data isolation: AI/ML systems operate in dedicated, network-segmented environments. Client data used for inference is not persisted beyond the session and is never used for model training.
- AI-specific penetration testing: Annual specialized penetration testing of all AI/ML systems covering OWASP Top 10 for LLM Applications (2025), including prompt injection, training data poisoning, model theft, and excessive agency.
- Access controls: All AI/ML model endpoints protected by the same Zero Trust policies as other firm systems. API keys rotated every 90 days. Usage logged and auditable.
- Vendor AI assessments: Third-party AI tools undergo security review covering model architecture, data handling, training practices, and compliance certifications before approval for use.

14. Physical Security

Meridian implements physical security controls across all 127 offices, 11 delivery centers, and 4 data center facilities to protect personnel, assets, and information:

- Badge access: All offices require proximity card (HID iCLASS) or biometric access. Badge access rights reviewed quarterly and revoked within 4 hours of termination or role change.
- Visitor management: All visitors must present government-issued ID, sign a visitor log, and be escorted by a badged employee at all times. Visitor badges are visually distinct and expire at end of business day.
- CCTV: Video surveillance at all entry/exit points, server rooms, and common areas. 90-day retention for standard footage; 1-year retention for security-sensitive areas. Monitored by the Global Security Operations Center.
- Clean rooms: Designated secure workspaces for engagements requiring enhanced physical security (defense, intelligence community, financial services M&A). Clean rooms feature: Faraday shielding, no-device policies, separate network segments, and restricted badge access limited to named individuals.
- Data center physical security: Tier IV facilities with multi-layer physical controls including mantrap entry, biometric + PIN access, 24/7 on-site guards, vehicle barriers, and seismic bracing. Access restricted to pre-approved personnel with background checks.
- Mail and package screening: All incoming mail and packages at major offices screened through X-ray scanners.